

// A FIELD REPORT



AI Automation vs. Legacy APIs

The Hidden Contracts Behind "The API Broke"

Sean Murray

Automation Engineer

When automation "breaks" an API, the usual explanations are wrong.

What people say

- ▶ The model hallucinated
- ▶ The integration is flaky
- ▶ We need a better prompt
- ▶ "The API broke"

What's actually going on

- ▶ Every call returned 200 OK
- ▶ Records looked fine and were quietly wrong
- ▶ A hidden contract never got written down
- ▶ Goodhart: it chased the status code, not the correct result

A 200 OK is the most dangerous thing the AI can hear.

Every system has two contracts

Explicit

Endpoints, schemas, status codes. What's in the docs.

Hidden

What the experienced colleague just *knows*. Five ways it bites you:

HIDDEN CONTRACT	IN PLAIN ENGLISH	WHAT GOES WRONG
Meaning	A field doesn't mean what it looks like	Price with or without tax; wrong unit of measure
Hidden workflow	One action runs a whole chain behind it	Create also reserves stock, sends email, assigns a number
Background	Who you are changes the answer	Company, language, timezone, defaults all shift the result
Sequence	Steps must happen in order	Skip a step and the totals come out wrong
Retry	Doing it twice should not do it twice	A timeout retry creates a duplicate record

All five can return 200 OK while being wrong.

Stable keys are not numeric IDs

STABLE KEY (SURVIVES RENUMBER)

product.steel_bracket

agent picks

→ numeric id

NUMERIC PK (CHANGES AFTER MIGRATE)

1842 991

IF YOU USED THE STABLE KEY

Same product. Still correct after renumber.

IF YOU HARDCODED 1842

200 OK — linked to the wrong row, or nothing.

Deploy before migrating

The trap

Ship the new code path first. Migration of the data (or the identifiers it depends on) comes later, or not at all.

What the AI sees

200 OK on writes against a world the old records never entered. Explicit schema looks fine. Sequence contract is broken.

Order of operations is a contract. Deploy and migrate are not interchangeable.

XML IDs vs numeric IDs

XML_ID / EXTERNAL ID

product.steel_bracket

What humans mean by "the product"

docs look like

either works?

NUMERIC PRIMARY KEY

1842

What this endpoint actually expects

RIGHT IDENTIFIER

Contract matches. Record links correctly.

SWAPPED IDENTIFIER

200 OK — wrong link, or a silent no-op. Meaning contract, not a network failure.

Best practices for accounting for hidden contracts

The model guesses the contract from field names and treats 200 as proof. It doesn't break APIs. It exposes what humans were quietly doing.

```
create_confirmed_thing(payload, idem_key)
    run the form logic          # defaults, validations, side effects
    dry-run, show a diff        # don't trust 200
    one idempotency key         # retries are safe
```

Better models won't save you. Turn tribal knowledge into explicit, enforced contracts.

"The API broke" is a review comment about **your** system, not the model's.

The fix • one safe verb

1

Raw create is the trap

Agents reach for `POST /things`. It returns `200 OK` while skipping form logic — and a retry can create a duplicate.

2

Don't expose the raw door

If the only tool is unconstrained create, the model will use it. Hide the unsafe verb from the agent.

3

Hand one safe verb

`create_confirmed_thing` — a single action that still means "do the whole job correctly."

4

Enforce the hidden contract

Run form logic inside the verb. Require an idempotency key. Same key twice → still one thing.

What to remember

- A 200 OK is not proof the business result is correct.
- Every system has two contracts: what's documented, and what operators quietly know.
- Hidden contracts show up as meaning, sequence, identity, retries — not as HTTP errors.
- Don't give the AI the raw API. Give it **one safe verb** that enforces the contract.

"The API broke" is a review comment about **your system, not the model's.**